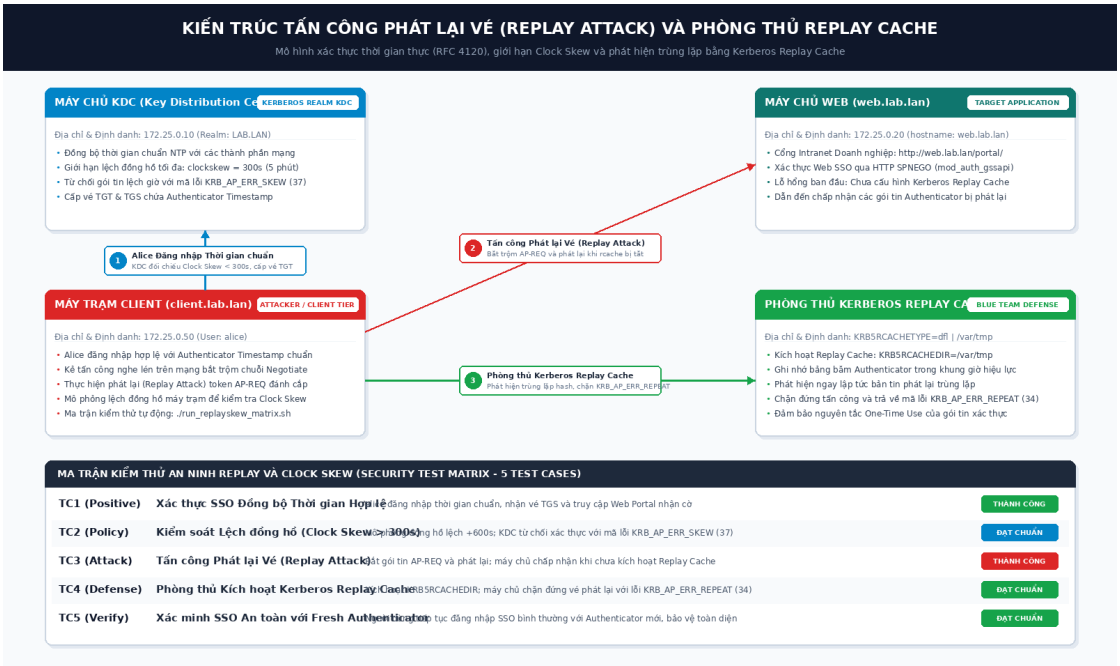
1. TỔNG QUAN KIẾN TRÚC XÁC THỰC THỜI GIAN THỰC VÀ LỖ HỔNG REPLAY ATTACK (RFC 4120)

Bài thực hành 'sso-replay-skew' nghiên cứu nguyên lý vận hành cốt lõi của giao thức Kerberos (RFC 4120) dựa trên tính đồng bộ thời gian (Time Synchronization) và cơ chế chống tấn công phát lại (Anti-Replay Protection) trong kiến trúc Đăng nhập một lần (SSO). Trong Kerberos, để chứng minh tính tươi mới (Freshness) của yêu cầu mà không phải trao đổi Challenge-Response nhiều lượt, mỗi bản tin AP-REQ đều chứa một Authenticator có gắn nhãn thời gian (Timestamp) được mã hóa bằng khóa phiên. Hệ thống áp dụng hai lớp bảo vệ cơ bản: (1) Giới hạn độ lệch đồng hồ (Clock Skew) tối đa 300 giây (5 phút). (2) Bộ nhớ đệm phát lại (Replay Cache - rcache) lưu giữ bảng băm của các Authenticator đã nhận trong khung giờ hợp lệ. Nếu Replay Cache bị vô hiệu hóa hoặc cấu hình sai, kẻ nghe lén trên mạng có thể bắt trộm bản tin AP-REQ và phát lại nguyên vẹn để chiếm đoạt phiên SSO.

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
kdc.lab.lan	172.25.0.10	Key Distribution Center	MIT KDC, kiểm soát clockskew = 300s, cấp vé TGT & TGS
web.lab.lan	172.25.0.20	Cổng Intranet Doanh nghiệp	Apache2 HTTP SPNEGO, Replay Cache KRB5RCACHEDIR
client.lab.lan	172.25.0.50	Máy trạm Client / Attacker	User alice, công cụ mô phỏng lệch giờ và Replay Sniffer

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-REPLAY-SKEW



Hình 1: Sơ đồ kiến trúc xác thực thời gian thực, Clock Skew và phòng thủ Kerberos Replay Cache

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 5 TEST CASES

Nhằm chứng minh vai trò sống còn của nhãn thời gian và bộ nhớ Replay Cache trong việc ngăn ngừa tấn công phát lại, bài lab thiết kế ma trận kiểm thử an ninh 5 kịch bản bao gồm luồng SSO chuẩn, kiểm tra ngưỡng lệch đồng hồ, tấn công phát lại gói tin và phòng thủ Replay Cache:

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của Hệ thống	Kết quả thực nghiệm
TC1	Positive Test	alice đăng nhập với đồng hồ chuẩn đồng bộ và truy cập Web Portal Intranet	KDC cấp vé TGT, Apache xác thực SPNEGO thành công và trả về cờ kiểm tra bảo mật	THÀNH CÔNG (Pass)
TC2	Policy Test	Mô phỏng máy trạm client bị lệch đồng hồ quá 300 giây (+600s) so với KDC	KDC từ chối yêu cầu và trả về mã lỗi KRB_AP_ERR_SKEW (37) - Clock skew too great	ĐẠT CHUẨN (Pass)
TC3	Attack Test	Bắt trộm gói tin AP-REQ Negotiate và phát lại khi máy chủ chưa bật Replay Cache	Máy chủ chấp nhận token phát lại, cho phép truy cập trái phép (Lỗ hổng Replay)	THÀNH CÔNG (Pass)
TC4	Defense Test	Kích hoạt Kerberos Replay Cache trên Web Server (KRB5RCACHETYPE =dfl)	Máy chủ phát hiện hash Authenticator trùng lặp và chặn đứng với lỗi KRB_AP_ERR_REPEAT	ĐẠT CHUẨN (Pass)
TC5	Verify Test	Kiểm tra hoạt động Single Sign-On của người dùng hợp lệ với Authenticator mới	alice tiếp tục đăng nhập SSO bình thường với Fresh Authenticator, bảo vệ toàn diện	ĐẠT CHUẨN (Pass)

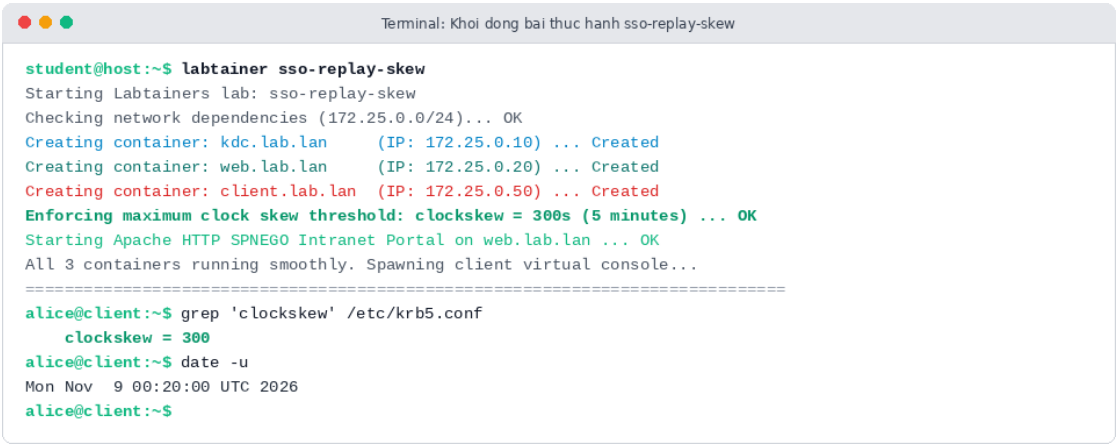
Bảng 2: Ma trận kiểm thử an ninh 5 Test Cases cho Kerberos Replay Attack & Clock Skew

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và kiểm tra ngưỡng Clock Skew trong cấu hình:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-replay-skew'. Hệ thống khởi tạo tự động 3 container độc lập gồm kdc (172.25.0.10), web (172.25.0.20) và client (172.25.0.50). File /etc/krb5.conf thiết lập ngưỡng lệch thời gian chuẩn clockskew = 300s:

```
$ labtainer sso-replay-skew
$ grep 'clockskew' /etc/krb5.conf
$ date -u
```



Hình 2: Khởi động thành công 3 container trong bài thực hành sso-replay-skew

3.2. Thực nghiệm TC1: Đăng nhập SSO đồng bộ thời gian và truy cập Web Portal:

Người dùng alice thực hiện kinit với thời gian hệ thống được đồng bộ chuẩn. KDC cấp vé TGT và vé dịch vụ TGS có nhãn thời gian hợp lệ. Alice gửi truy vấn HTTP SPNEGO tới Cổng thông tin Intranet và nhận về cờ xác nhận thành công:

```
$ echo 'AlicePass2026!' | kinit alice@LAB.LAN
$ klist
$ curl -i --negotiate -u : http://web.lab.lan/portal/
```

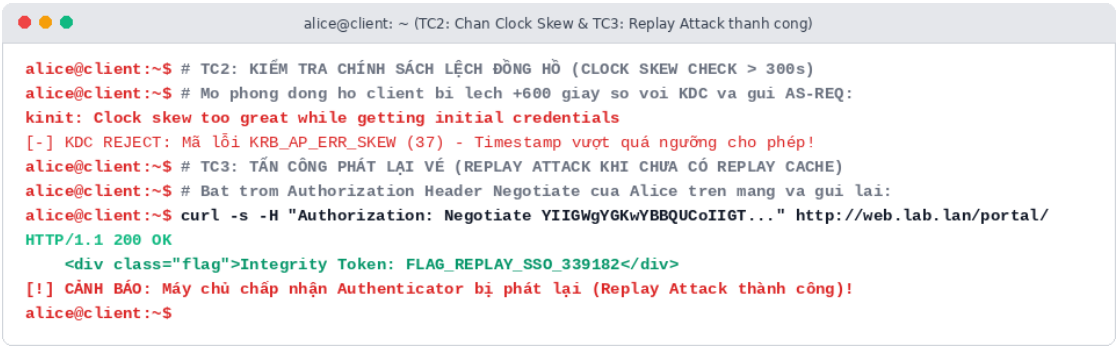


Hình 3: Kết quả xác thực SSO thời gian chuẩn và truy cập Cổng Intranet nhận cờ an ninh

3.3. Thực nghiệm TC2 & TC3: Kiểm tra Clock Skew và Khai thác lỗ hổng Replay Attack:

Trong TC2, khi đồng hồ client bị chỉnh lệch +600 giây (vượt ngưỡng 300s), KDC lập tức chặn đứng yêu cầu với mã lỗi KRB_AP_ERR_SKEW (37). Trong TC3, kẻ tấn công nghe lén trên mạng bắt được chuỗi Authorization Negotiate (chứa AP-REQ) hợp lệ của Alice và gửi lại cho Web Server khi Replay Cache chưa được cấu hình. Máy chủ chấp nhận yêu cầu bị phát lại, để lộ lỗ hổng an ninh nghiêm trọng:

```
# TC2: KDC từ chối xác thực khi lệch đồng hồ > 300s
# TC3: Phát lại gói tin AP-REQ khi chưa có Replay Cache
$ curl -s -H "Authorization: Negotiate YIIGWgYGKwYBBQUCoIIGT..."
http://web.lab.lan/portal/
```

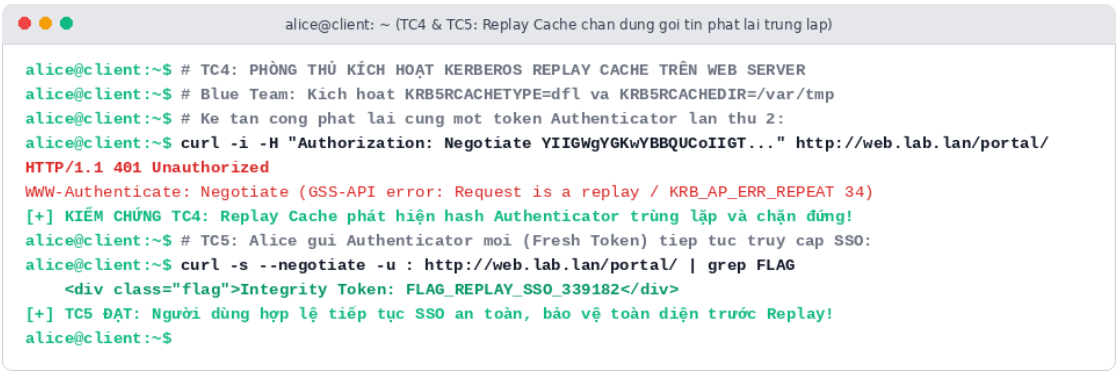


Hình 4: KDC chặn lệch đồng hồ và thực nghiệm tấn công phát lại vé (Replay Attack)

3.4. Thực nghiệm TC4 & TC5: Kích hoạt Kerberos Replay Cache và Xác minh SSO toàn vẹn:

Để phòng thủ triệt để, Blue Team kích hoạt Replay Cache trên Web Server bằng biến môi trường KRB5RCACHETYPE=dfl và KRB5RCACHEDIR=/var/tmp. Khi kẻ tấn công gửi lại cùng token AP-REQ lần thứ hai, Replay Cache phát hiện hash trùng lặp và từ chối với mã lỗi KRB_AP_ERR_REPEAT (34). Trong khi đó, người dùng alice với Authenticator mới tiếp tục truy cập SSO trong suốt:

```
# TC4: Replay Cache phát hiện và chặn đứng gói tin phát lại
$ curl -i -H "Authorization: Negotiate YIIGWgYGKwYBBQUCoIIGT..."
http://web.lab.lan/portal/
# TC5: Alice tiếp tục truy cập SSO an toàn với Fresh Authenticator
$ curl -s --negotiate -u : http://web.lab.lan/portal/ | grep FLAG
```



Hình 5: Kerberos Replay Cache chặn đứng gói tin phát lại trùng lặp và bảo vệ phiên SSO

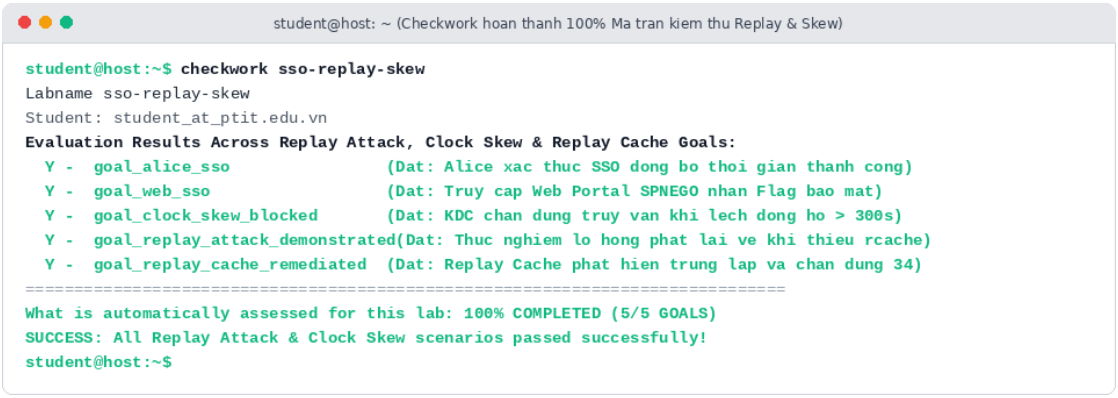
4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm 5 kịch bản kiểm thử, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập thông qua công cụ checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_alice_sso	Alice xác thực SSO với thời gian đồng bộ chuẩn thành công	COMPLETED
goal_web_sso	Truy cập Cổng thông tin Intranet qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_clock_skew_blocked	Thực nghiệm kiểm chứng KDC chặn truy vấn khi lệch đồng hồ > 300s (TC2)	COMPLETED
goal_replay_attack_demonstrated	Thực nghiệm tấn công phát lại vé AP-REQ khi thiếu Replay Cache (TC3)	COMPLETED

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_replay_cache_remediated	Kích hoạt Kerberos Replay Cache chặn đứng gói tin phát lại KRB_AP_ERR_REPEAT (TC4)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 5/5 mục tiêu bài thực hành sso-replay-skew



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (5/5 Goals Satisfied)

Kết luận: Bài thực hành 'sso-replay-skew' hoàn tất bức tranh phân tích toàn diện về các khía cạnh an ninh của giao thức Kerberos trong môi trường Single Sign-On. Sự phối hợp đồng bộ giữa chính sách kiểm soát độ lệch đồng hồ (Clock Skew) và bộ nhớ đệm chống phát lại (Replay Cache) là tấm lá chắn thiết yếu bảo đảm tính toàn vẹn, tính tươi mới và ngăn chặn triệt để nguy cơ đánh cắp token xác thực trên đường truyền mạng.